

Limit SAMPLESPERPIXEL to avoid runtime DOS #6700

New issue

Merged

hugovk merged 5 commits into `python-pillow:main` from `hugovk:security-samples_per_pixel-sec` on Oct 29, 2022

Conversation 0

Commits 5

Checks 0

Files changed 4

+35 -1



hugovk commented on Oct 29, 2022 Member

A large value in the `SAMPLESPERPIXEL` tag could lead to a memory and runtime DOS in `TiffImagePlugin.py` when setting up the context for image decoding.

This was introduced in Pillow 9.2.0, found with [OSS-Fuzz](#) and fixed by limiting `SAMPLESPERPIXEL` to the number of planes that we can decode.

Reviewers

No reviews

Assignees

No one assigned

Labels

TIFF

Projects

None yet

Milestone

9.3.0

Development

Successfully merging this pull request may close these issues.

None yet

3 participants



wiredfool and others added 5 commits 4 years ago

- Prevent DOS with large `SAMPLESPERPIXEL` in Tiff IFD ... `13f2c5a`
- Tighter test case `05b175e`
- Hide UserWarning in logs ... `00b25fd`
- Fix linting `799a6a0`
- Add to release notes `0846bfa`

hugovk added this to the 9.3.0 milestone on Oct 29, 2022

radarhere added the TIFF label on Oct 29, 2022

hugovk merged commit `2444cdd` into `python-pillow:main` on Oct 29, 2022



hugovk deleted the `security-samples_per_pixel-sec` branch 4 years ago



Lucas-C mentioned this pull request on Dec 15, 2022

fpdf2 depends on Pillow version
having security vulnerability py-
pdf/fpdf2#628

🔒 Closed



Dawars mentioned this pull request on Mar 14, 2023

Update to 9.4.0 to fix security
vulnerabilities uploadcare/pillow-
simd#129

🔒 Closed



rickprice mentioned this pull request on Apr 22, 2023

BE-2346-cve-2022-45199
ActiveState/Pillow#20

🔗 Merged



G-Rath mentioned this pull request on May 17, 2023

PYSEC-2022-42980: affected range is
wrong pypa/advisory-database#118

🔒 Closed



sync-by-unito bot mentioned this pull request on Aug 28, 2023

Bump pillow from 9.2.0 to 9.3.0
toddbirchard/ghost-webhook-api#285

🔒 Closed